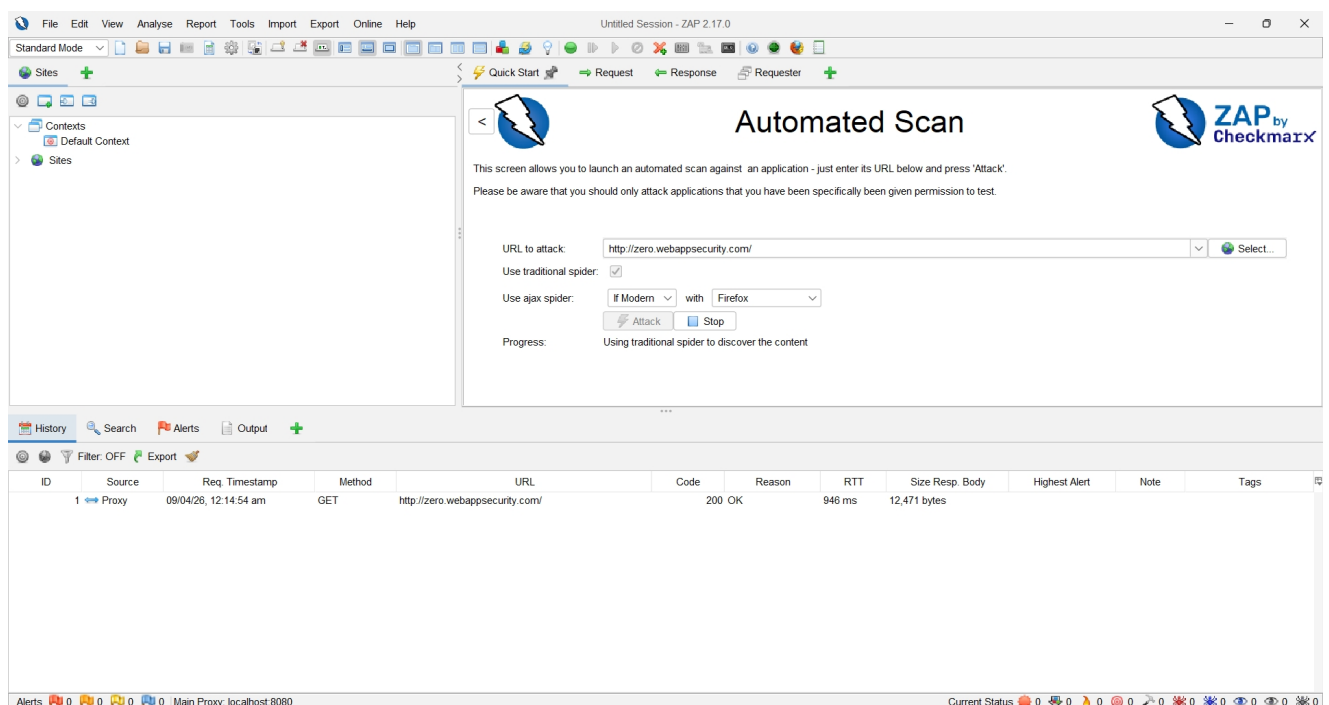


Experiment 11

AIM: Use OWASP ZAP to check security integrity.

1. Install ZAP
Download OWASP ZAP
Install and open
2. Quick Start
You'll see: "Quick Start" screen
Click:
Automated Scan
3. Enter Target URL
Use safe demo site:
<http://zero.webappsecurity.com/>
4. Start Scan
Click:
Attack
5. Verify Results
Alerts
Risk levels:
High
Medium
Low



The screenshot displays the ZAP (Zed Attack Proxy) interface during an automated scan. The main window shows the 'Automated Scan' screen, which includes a text input field for the URL to attack, set to 'http://zero.webappsecurity.com/'. Below this, there are checkboxes for 'Use traditional spider' (checked) and 'Use ajax spider' (unchecked). The 'Attack' button is highlighted. The progress bar indicates 'Actively scanning (attacking) the URLs discovered by the spider(s)'. The left sidebar shows the 'Alerts' tab, which lists several alerts, including 'Content Security Policy (CSP) Header Not Set (5)'. The bottom status bar shows the current status of the scan, including the number of alerts and the current status of the scan.

The screenshot displays the ZAP web application security tool's "Automated Scan" configuration window. The interface includes a top menu bar with options like File, Edit, View, Analyse, Report, Tools, Import, Export, Online, and Help. Below the menu is a toolbar with various icons. On the left, there are panels for "Sites", "Contexts", and "Default Context". The main area shows the "Automated Scan" title with the ZAP logo and Checkmarx branding. A descriptive paragraph states: "This screen allows you to launch an automated scan against an application - just enter its URL below and press 'Attack'." It also includes a warning: "Please be aware that you should only attack applications that you have been specifically given permission to test." The configuration fields include: "URL to attack:" set to "http://zero.webappsecurity.com/", "Use traditional spider:" checked, "Use ajax spider:" set to "If Modern" with "Firefox" as the engine, and "Progress:" indicating "Actively scanning (attacking) the URLs discovered by the spider(s)". At the bottom, there is a status bar showing "Current Scans: 1", "Num Requests: 272", "New Alerts: 0", and an "Export" button. Below the status bar is a table of scan results with columns: ID, Req. Timestamp, Resp. Timestamp, Method, URL, Code, Reason, RTT, Size Resp. Header, and Size Resp. Body. The table contains 16 rows of data, all with a status of "OK".